Within the "webfuzzing_hidden_path" path on the target system (ie http://IP:PORT/webfuzzing_hidden_path/), fuzz for folders and then files to find the flag.

To jest nasze proste zadanie.
Zrobiłem to tak:
ffuf -u http://154.57.164.83:42939/webfuzzing_hidden_path/FUZZ -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -e .php,.html,.txt,.bak,.js -v

Znalazłem coś takiego:
/webfuzzing_hidden_path/flag/
    * FUZZ: flag

Następnie p[szukałem folder pod kątem plików z flagą

└──╼ [★]$ ffuf -u http://154.57.164.83:42939/webfuzzing_hidden_path/flag/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -e .php,.html,.txt,.bak,.js -v

a o to wyniki

```
[Status: 200, Size: 100, Words: 2, Lines: 2, Duration: 6ms]
| URL | http://154.57.164.83:42939/webfuzzing_hidden_path/flag/flag.html
e    * FUZZ: flag.html

[Status: 200, Size: 104, Words: 6, Lines: 2, Duration: 6ms]
| URL | http://154.57.164.83:42939/webfuzzing_hidden_path/flag/index.html
    * FUZZ: index.html

[Status: 200, Size: 104, Words: 6, Lines: 2, Duration: 7ms]
| URL | http://154.57.164.83:42939/webfuzzing_hidden_path/flag/index.html
    * FUZZ: index.html
```

resztę wyciągnę z curla i wpisze gdzie trzeba

Notatka

- `Discovery/Web-Content/common.txt`: podstawowe zbior nazw plików i folderów
- `Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt`:głębsze i bardziej zaawansowane nazwy folderów. dobre do głębokiego penetrowania
- `Discovery/Web-Content/raft-large-directories.txt`: do dużych folderów

- `Discovery/Web-Content/big.txt`: duze działo do duzych korporacji

```
ffuf -w
/usr/share/seclists/Discovery/Web-Content/DirBuster-2007_direc
tory-list-2.3-medium.txt -ic -u http://IP:PORT/FUZZ -e .html
-recursion -recursion-depth 2 -rate 500
```

`Initial Fuzzing`
fuzowanie klasyczne - przeszukanie jakie mamy dostępne foldery
`Directory Discovery and Expansion` :
eksplorowanie nowych folderów i użycie nowych ścieżek do dalszego eksplorowania, to co wcześniej zrobione
`Iterative Depth`
to co powyżej tylko że automatycznie aż dopóki nie znajdzie wszystkich możliwości

W ffuf wykorzystamy to za pomocą -recrusion
Jest to fajne ale może obciążać serwer i zaalarmować firmę ze cos sie dzieje
`-recursion-depth` - ile poziomów moze sie zapuscic agent
`-recursion-depth` 2 itp.

`-rate -` ile on wysyła requestów na daną jednostkę

`-timeout` Ta opcja określa limit czasu dla poszczególnych żądań, co pomaga zapobiegać zawieszaniu się fuzzera na nieodpowiadających celach.

Recursively fuzz the "recursive_fuzz" path on the target system (ie http://IP:PORT/recursive_fuzz/) to find the flag.

nasze zadanie
res

przykład

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -ic -v -u http://IP:PORT/FUZZ -e .html -recursion
```

```
gobuster vhost -u http://inlanefreight.htb:81 -w
/usr/share/seclists/Discovery/Web-Content/common.txt
--append-domain
```

```
vhost -u  skupia się na odkryciu wirtualnych hostów
```

```
-u http://inlanefreight.htb:81 - targret
```

```
gobuster dns -d inlanefreight.com -w
/usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.
txt
```

```
dns - skupienie sie na szukaniu domen dns
```

```
-d inlanefreight.com - target
```

Using GoBuster against the target system to fuzz for vhosts using the common.txt wordlist, which vhost starts with the prefix "web-"? Respond with the full vhost, eg web-123.inlanefreight.htb.

```
gobuster vhost -u http://154.57.164.65:39188 -w
/usr/share/seclists/Discovery/Web-Content/common.txt
--append-domain | grep "web"
```

```
używamy grep do filtrowania
gobuster vhost -u http://inlanefreight.htb:39188 -w
/usr/share/seclists/Discovery/Web-Content/common.txt
--append-domain | grep "web-"
```

Using GoBuster against inlanefreight.com to fuzz for subdomains using the subdomains-top1million-5000.txt wordlist, which subdomain starts with the prefix "su"? Respond with the full vhost, eg web.inlanefreight.com.

```
gobuster dns -d inlanefreight.com -w
/usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.
txt | grep "su"
```

What is the value returned by the endpoint that the api fuzzer has identified?

zrobiłem to:

```
git clone https://github.com/PandaSt0rm/webfuzz_api.git
```

```
pip3 install -r requirements.txt
```

```
python3 api_fuzzer.py http://IP:PORT
```

Zastąp adres url swoim co tam masz.
a następnie sprawdzasz w curl co tam wyskoczy w endpoint